

Compliance Audit CCEE Cheat Sheet

Detailed revision guide for PGCP-ITISS Compliance Audit

Use this for last-minute framework mapping, audit phases, evidence, laws, standards, and case-study style answers.

1. Compliance Audit Basics

Meaning of Compliance

Compliance means following the applicable:

Area	Examples
Laws	IT Act, DPDP Act, GDPR, HIPAA, SOX
Standards	ISO/IEC 27001, PCI DSS, CIS Benchmarks
Internal policies	Password policy, backup policy, access control policy
Contracts	Vendor SLA, data processing agreement
Regulatory requirements	RBI, SEBI, industry-specific rules

Compliance Audit Meaning

A compliance audit checks whether an organization is following required laws, standards, regulations, policies, and procedures.

Compliance audit verifies whether controls, processes, documentation, and evidence meet applicable legal, regulatory, contractual, and internal policy requirements.

Security vs Compliance

Security	Compliance
Protects systems and data from threats	Proves rules and standards are followed
Risk-focused	Requirement-focused
Example: MFA reduces unauthorized access	Example: MFA required by policy and verified in audit
Can exist without documentation but hard to prove	Requires documentation and evidence

A company can be compliant but still insecure if it only meets minimum requirements. A company can also be secure but fail an audit if it lacks evidence.

2. Cybersecurity Challenges for Organizations

Common Challenges

Challenge	Meaning	Audit Concern
Data breaches	Unauthorized access/disclosure of data	Was data encrypted? Were logs reviewed?
Ransomware	Malware encrypts data and demands payment	Are backups tested? Is IR plan ready?
Insider threats	Employees misuse access	Are access reviews performed?
Cloud misconfiguration	Exposed S3 buckets, weak IAM, public databases	Is cloud configuration audited?
Third-party risk	Vendors mishandle data	Are vendors assessed?
Remote work	Personal networks/devices increase attack surface	Is VPN/MFA/endpoint security enforced?
Regulatory complexity	Multiple laws apply	Is compliance mapping maintained?
Lack of evidence	Controls exist but proof is missing	Audit finding due to weak documentation

Most Audit-Friendly Evidence

Control	Strong Evidence
Backup	Backup logs + restoration test report
Access control	User access review report + approval records
Patch management	Patch report + vulnerability scan report
Incident response	IR plan + incident tickets + post-incident review
Training	Attendance records + awareness material + test results
Vendor compliance	Vendor risk assessment + contract + SOC/ISO reports

Verbal confirmation is weak evidence. Logs, screenshots, reports, tickets, and approvals are stronger evidence.

3. Types of Security Audit

Audit Type	Purpose	Example
Internal audit	Readiness check by internal team	Checking ISO 27001 readiness before certification
External audit	Independent third-party audit	Certification audit
Compliance audit	Checks rules/regulations/policies	GDPR, PCI DSS, ISO audit
Configuration audit	Checks system/device hardening	Firewall ACL review, CIS Benchmark check
Forensic audit	Investigation after suspicious activity	Employee copied confidential files
Operational audit	Checks efficiency/effectiveness of processes	IT operations process review
Vendor audit	Checks third-party/service provider compliance	Cloud provider security review
Financial audit	Checks financial records and reporting	Statutory financial audit
Access control audit	Checks user permissions and least privilege	Resigned user account still active
Physical security audit	Checks physical access controls	CCTV, visitor logs, server room access

Audit Type Quick Identification

Scenario Keyword	Answer
before external certification	Internal audit
independent auditor for ISO certification	External certification audit
suspected fraud/breach/evidence/legal action	Forensic audit
firewall rules, OS hardening, baseline	Configuration audit
third-party provider, SLA, contract	Vendor audit
roles, permissions, resigned employees	Access control audit

4. Audit Decision Factors

Auditors decide audit priority based on risk.

High-Priority Audit Factors

Factor	Why It Matters
Data sensitivity	Personal, financial, health, card data need stronger controls
Business criticality	Critical systems impact operations
Internet exposure	Public-facing apps have higher attack risk
Regulatory impact	PCI/GDPR/HIPAA/SOX increase audit importance
Past incidents	Repeated issues increase audit priority
Control weakness history	Weak controls need rechecking
Third-party dependency	Vendor failure can create compliance risk
Change frequency	Frequently changed systems have higher misconfiguration risk

High risk + high business impact + sensitive data + legal requirement = audit first.

5. Security Audit Phases

Standard Audit Lifecycle

Phase	Activities
1. Planning	Define scope, objective, criteria, timeline, team, checklist
2. Opening meeting	Discuss audit plan with auditee
3. Fieldwork / evidence collection	Collect logs, screenshots, policies, configs, interviews
4. Analysis / testing	Compare actual controls with requirements
5. Gap identification	Identify non-compliance and control weakness
6. Reporting	Prepare findings, risk rating, recommendations
7. Management response	Auditee accepts/rejects and gives action plan
8. Remediation	Fix gaps
9. Follow-up / closure	Verify evidence and close findings

Audit Finding Format

Element	Meaning
Condition	What is currently happening
Criteria	What policy/standard requires
Cause	Why the gap exists
Impact	What can go wrong
Recommendation	What should be done
Evidence	Logs/screenshots/reports/tickets

Example:

Finding: Inactive user accounts were not disabled within 24 hours as required by access control policy. Impact: Unauthorized access risk. Recommendation: Implement automated deprovisioning and periodic access review. Evidence: User list, HR exit records, access review report.

6. Internal Audit Team Requirements

Important Qualities

Requirement	Meaning
Independence	Auditor should not audit their own work
Objectivity	Findings should be unbiased
Competence	Auditor must understand controls/frameworks
Confidentiality	Audit information must be protected
Professional care	Work should be careful, complete, and evidence-based
Communication skill	Auditor must ask clear questions and explain findings
Documentation skill	Evidence and findings must be properly recorded

Maker should not be the checker.

Example: If firewall admins implemented firewall rules, they should not be the only team auditing those firewall rules.

7. Principles of Audit

Principle	Meaning	Exam Example
Integrity	Auditor should be honest and ethical	Do not manipulate findings
Fair presentation	Report truthfully and accurately	Do not hide serious issues
Due professional care	Audit carefully and competently	Use proper judgment
Confidentiality	Protect audit information	Do not share findings with unauthorized people

Independence	Avoid conflict of interest	Do not audit own work
Evidence-based approach	Findings must be supported by proof	Logs/screenshots/reports required
Risk-based approach	Focus more on high-risk areas	Audit payment system before cafeteria app

8. Security Evaluation

Meaning

Security evaluation checks whether a product/system meets security requirements and whether controls are properly designed, implemented, tested, and effective.

Security Evaluation vs Security Audit

Security Evaluation	Security Audit
Evaluates security claims, design, implementation, testing	Verifies compliance with rules/standards/policies
Often product/system focused	Organization/process/control focused
Concerned with assurance	Concerned with compliance and evidence

Evaluation Process

Phase	Activities
Planning	Define evaluation scope and criteria
Evidence collection	Collect security target, design docs, test reports
Analysis	Review security design and claims
Testing	Verify security functions
Vulnerability analysis	Check known weaknesses
Reporting	Document evaluation results

Assurance

Security assurance means confidence that security controls are correctly implemented and will behave as expected.

Assurance does not mean "impossible to hack." It means higher confidence based on evaluation.

7 Evaluation Assurance Levels

Usually taught as increasing levels of confidence.

Level	Meaning
Level 1	Basic assurance
Level 2	Structurally tested
Level 3	Methodically tested and checked
Level 4	Methodically designed, tested, and reviewed
Level 5	Semiformally designed and tested
Level 6	Semiformally verified design and tested
Level 7	Formally verified design and tested

Higher level = more rigorous evaluation, not guaranteed zero vulnerability.

9. NIST Cybersecurity Framework

The older/classic NIST CSF model commonly taught in syllabus uses five functions: Identify, Protect, Detect, Respond, Recover. NIST CSF 2.0 added Govern, making the current official functions Govern, Identify, Protect, Detect, Respond, Recover. For CCEE, answer according to the option pattern: if classic five are given, choose the classic five.

Source: NIST Cybersecurity Framework 2.0, nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf

NIST CSF Functions

Function	Meaning	Examples
Govern	Establish cybersecurity governance, roles, policy, risk strategy	Security policy, risk appetite, oversight
Identify	Know assets, risks, business context	Asset inventory, risk assessment
Protect	Safeguards to prevent/reduce impact	MFA, encryption, training
Detect	Identify cybersecurity events	SIEM, IDS, log monitoring
Respond	Take action after incident detection	IR plan, containment, communication
Recover	Restore normal operations	Backup restore, DR, lessons learned

Memory Mapping

Keyword in Question	NIST Function
Assets, business environment, risk assessment	Identify
MFA, access control, training, encryption	Protect
Logs, alerts, anomaly detection	Detect
Incident handling, mitigation, communication	Respond
Restore, backup, DR, business continuity	Recover
Policy, oversight, risk strategy, roles	Govern

10. GDPR

GDPR protects personal data of individuals in the European Union and can apply even to organizations outside the EU if they process EU individuals' personal data.

Personal Data

Personal data means data that can identify a person directly or indirectly.

Type	Examples
Direct identifiers	Name, email, phone number
Online identifiers	IP address, cookie ID
Location data	GPS location
Financial data	Bank details
Sensitive/special category	Health, biometric, genetic, religion, political opinion

GDPR Roles

Role	Meaning
Data Subject	Individual whose data is processed
Data Controller	Decides why and how data is processed
Data Processor	Processes data on behalf of controller
Supervisory Authority	Regulatory authority
DPO	Data Protection Officer, where required

Controller decides purpose and means. Processor follows controller's instructions.

GDPR Principles

Principle	Meaning
Lawfulness, fairness, transparency	Process data legally and clearly
Purpose limitation	Use data only for specified purpose
Data minimization	Collect only necessary data
Accuracy	Keep data correct and updated
Storage limitation	Do not keep data longer than needed
Integrity and confidentiality	Protect data with security controls

Accountability	Be able to prove compliance
----------------	-----------------------------

GDPR Rights

Right	Meaning
Right to access	Individual can ask what data is held
Right to rectification	Correct inaccurate data
Right to erasure	Delete data under certain conditions
Right to restrict processing	Limit processing
Right to data portability	Receive data in portable format
Right to object	Object to processing
Rights around automated decision-making	Protection from certain automated decisions

GDPR Compliance Evidence

Requirement	Evidence
Consent	Consent logs, consent forms
Data processing	Record of processing activities
Privacy notice	Published privacy policy
DPIA	Data Protection Impact Assessment
Breach handling	Breach response procedure and incident records
Data subject rights	Request handling records
Vendor processing	Data Processing Agreement
Retention	Data retention and deletion policy

GDPR breach notification requires notifying the supervisory authority without undue delay and, where feasible, within 72 hours after becoming aware of a personal data breach that is likely to result in risk to individuals.

11. ISO/IEC 27001 and ISO 2700x

ISO/IEC 27001

ISO/IEC 27001 is the standard for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS).

ISMS

An ISMS is a structured system of:

ISMS Component	Meaning
Policies	Security rules
Risk assessment	Identify and analyze risks
Risk treatment	Decide controls
Roles and responsibilities	Assign accountability
Monitoring	Check control performance
Internal audit	Verify ISMS effectiveness
Management review	Top management review
Continual improvement	Correct and improve

ISO 2700x Family

Standard	Purpose
ISO/IEC 27000	Overview and vocabulary
ISO/IEC 27001	ISMS requirements
ISO/IEC 27002	Guidance for security controls
ISO/IEC 27005	Information security risk management
ISO/IEC 27017	Cloud security controls

ISO/IEC 27018	Protection of PII in public cloud
ISO/IEC 27701	Privacy information management extension

ISO 27001 Key Documents

Document	Purpose
ISMS scope	Defines boundaries of ISMS
Information security policy	High-level security direction
Risk assessment report	Identifies and rates risks
Risk treatment plan	Defines how risks will be treated
Statement of Applicability	Lists included/excluded controls with justification
Internal audit report	Audit observations
Management review minutes	Top management review evidence
Corrective action records	Proof of improvement

Statement of Applicability

The SoA is one of the most important ISO 27001 documents.

It contains:

SoA Content	Meaning
Selected controls	Controls organization will implement
Excluded controls	Controls not applicable
Justification	Why included/excluded
Implementation status	Implemented, partial, not implemented

SoA connects risk treatment with selected controls and implementation status.

ISO 27001 Clauses Quick Mapping

Clause Area	Keywords
Context of organization	Interested parties, internal/external issues, ISMS scope
Leadership	Top management, policy, roles
Planning	Risks, opportunities, objectives
Support	Awareness, competence, communication, documented information
Operation	Risk assessment and risk treatment execution
Performance evaluation	Monitoring, measurement, internal audit, management review
Improvement	Nonconformity, corrective action, continual improvement

PDCA Cycle

Step	Meaning
Plan	Identify risks, plan controls
Do	Implement controls
Check	Monitor, audit, review
Act	Improve and correct

Exam Traps

Question Says	Correct Area
Employees unaware, no training evidence	Support
Internal audit, metrics, management review	Performance evaluation
Risk assessment and risk treatment	Operation
Interested parties and ISMS scope	Context
Corrective action after nonconformity	Improvement

12. SOX and SOC Reports

SOX

SOX stands for Sarbanes-Oxley Act. It focuses on financial reporting accuracy, internal controls, and accountability for public companies.

Why IT Controls Matter in SOX

Financial reporting depends on IT systems like ERP, payroll, databases, and financial applications. So IT controls become important.

SOX IT General Controls

ITGC Area	Example
Access control	User access review for finance system
Change management	Production changes approved and tested
Backup and recovery	Financial data recoverable
Job scheduling	Batch jobs run correctly
System operations	Monitoring and incident handling
Audit logging	Logs for financial systems

SOX Sections

Section	Meaning
Section 302	CEO/CFO certify financial reports and disclosure controls
Section 404	Management assesses internal controls over financial reporting
Section 409	Real-time disclosure of material changes
Section 802	Penalties for altering/destroying records

302 = management certification. 404 = internal control assessment/testing.

SOC Reports

SOC reports are independent assurance reports for service organizations.

SOC Report	Purpose
SOC 1	Controls relevant to customer financial reporting
SOC 2	Controls based on Trust Services Criteria
SOC 3	Public/general-use summary report

SOC 2 Trust Services Criteria

Criteria	Meaning
Security	Protection against unauthorized access
Availability	System available as committed
Processing integrity	Complete, valid, accurate processing
Confidentiality	Confidential data protected
Privacy	Personal information handled properly

Type I vs Type II

Type	Meaning
Type I	Control design at a point in time
Type II	Control design and operating effectiveness over a period

Type I = snapshot. Type II = movie.

SOC Exam Mapping

Scenario	Correct Answer
Payroll provider impacts financial reporting	SOC 1
Cloud provider security/availability/privacy controls	SOC 2
Public shareable assurance report	SOC 3
January to June operating effectiveness	Type II
One-day design review	Type I

13. COBIT Framework

COBIT is used for governance and management of enterprise IT.

COBIT Focus

COBIT Helps With
Aligning IT with business goals
Managing IT risk
Delivering business value
Measuring IT performance
Establishing IT controls
Supporting governance and compliance

COBIT = IT governance, business alignment, risk, value, and control.

COBIT Domains

Domain	Full Form	Purpose
EDM	Evaluate, Direct, Monitor	Governance
APO	Align, Plan, Organize	Strategy and planning
BAI	Build, Acquire, Implement	Building and implementing solutions
DSS	Deliver, Service, Support	Operations and service delivery
MEA	Monitor, Evaluate, Assess	Performance and compliance monitoring

COBIT vs ITIL

COBIT	ITIL
IT governance	IT service management
Board/management focused	Operations/service focused
Controls, risk, business alignment	Incident, problem, change, service desk
Are we governing IT properly?	Are we delivering IT services properly?

ITIL runs the service. COBIT governs the service.

14. HIPAA

HIPAA protects Protected Health Information (PHI). The HIPAA Privacy Rule establishes national standards to protect medical records and individually identifiable health information, while the HIPAA Security Rule protects electronic PHI using administrative, physical, and technical safeguards.

Source: HHS HIPAA Privacy Rule and Security Rule resources, [hhs.gov/hipaa](https://www.hhs.gov/hipaa)

PHI Examples

PHI Type	Examples
Identity	Patient name, address, phone
Medical	Diagnosis, lab report, treatment history
Insurance	Policy number, claim details
Billing	Medical billing information
Digital	Medical record number, health portal login data

HIPAA Rules

Rule	Meaning
Privacy Rule	Use/disclosure of PHI and patient rights
Security Rule	Protection of ePHI
Breach Notification Rule	Notification after breach of unsecured PHI
Enforcement Rule	Penalties and enforcement
Transactions and Code Sets Rule	Standard electronic healthcare transactions
Unique Identifiers Rule	Standard identifiers for entities

The HIPAA Breach Notification Rule requires covered entities and business associates to provide notification after a breach of unsecured protected health information.

HIPAA Safeguards

Safeguard	Examples
Administrative	Risk analysis, policies, workforce training
Physical	Facility access, workstation security, device controls
Technical	Unique user IDs, audit logs, encryption, automatic logoff

Exam Traps

Question Says	Correct Answer
Protect ePHI with admin/physical/technical safeguards	Security Rule
Patient rights and use/disclosure of PHI	Privacy Rule
Notify affected individuals after breach	Breach Notification Rule
Unique user ID, encryption, audit logs	Technical safeguards
Training and risk analysis	Administrative safeguards
Server room access/workstation controls	Physical safeguards

15. PCI DSS

PCI DSS applies to organizations that store, process, or transmit payment card/cardholder data. PCI DSS provides technical and operational requirements to protect payment account data.

Source: PCI Security Standards Council, pcisecuritystandards.org/standards/pci-dss

PCI DSS Data Types

Data Type	Examples	Storage Rule
Cardholder data	PAN, cardholder name, expiry date, service code	Can be stored if protected
Sensitive authentication data	CVV/CVC, full magnetic stripe, PIN/PIN block	Must not be stored after authorization

PAN is the core cardholder data element. CVV must not be stored after authorization, even if encrypted.

PCI DSS Requirement Areas

Requirement Area	Meaning
Secure network and systems	Firewalls, secure configs
Protect account data	PAN encryption, masking, key management
Vulnerability management	Malware protection, secure development
Strong access control	Need-to-know, MFA, unique IDs
Monitor and test networks	Logs, scans, penetration testing
Information security policy	Maintain and communicate policy

PCI DSS Audit Keywords

Scenario	Correct Concept
Firewalls/network security controls	Build and maintain secure network
Default passwords unchanged	Secure configuration weakness
PAN stored in plaintext	Protect stored account data
CVV stored after authorization	Serious PCI violation
Full PAN visible to everyone	Need-to-know violation
Only last 4 digits required	Mask PAN
Quarterly ASV scan	Regular security testing
No logs/alerting	Track and monitor access
Outdated security policy	Maintain information security policy
Flat network with CDE and guest Wi-Fi	Segmentation/scope issue

PCI Merchant Levels

Merchant levels are generally based on transaction volume and determine validation requirements such as SAQ, ROC, or external assessment expectations.

Term	Meaning
SAQ	Self-Assessment Questionnaire
ROC	Report on Compliance
AOC	Attestation of Compliance
ASV	Approved Scanning Vendor
CDE	Cardholder Data Environment

Outsourcing payment processing reduces PCI scope but does not remove all PCI responsibility.

PCI SSC published PCI DSS v4.0.1 as the supported version after PCI DSS v4.0 retirement; for CCEE, your syllabus may still test the general PCI DSS concepts rather than version-specific wording.

16. CIS Controls and CIS Benchmarks

CIS Critical Security Controls

CIS Controls are prioritized cybersecurity best practices used to reduce common cyberattack risks.

CIS Benchmarks

CIS Benchmarks are secure configuration guidelines for systems, applications, cloud platforms, and network devices.

CIS Controls vs CIS Benchmarks

CIS Controls	CIS Benchmarks
What security actions to do	How to configure securely
High-level control areas	Detailed hardening settings
Example: Inventory assets	Example: Disable root SSH login in Linux
Example: Vulnerability management	Example: Password complexity setting

Important CIS Control Areas

Control Area	Example
Inventory of enterprise assets	List laptops, servers, cloud instances
Inventory of software assets	Approved software list
Secure configuration	Harden Windows/Linux/network devices
Vulnerability management	Patch and track vulnerabilities
Access control management	MFA, least privilege, admin review
Audit log management	Centralized logging
Malware defenses	Endpoint protection
Data recovery	Backup and restore testing
Network monitoring	IDS, alerts
Security awareness	Employee training
Incident response	IR process and testing

Exam Traps

Scenario	Correct CIS Concept
Unknown laptops/servers	Inventory of enterprise assets
Unauthorized software	Inventory of software assets
Default Linux config	Secure configuration
Monthly patching	Vulnerability management
Shared admin accounts	Access control management
Backup and restore testing	Data recovery
Compare Windows Server with CIS Benchmark	Hardening baseline deviation

17. SSE-CMM

SSE-CMM stands for Systems Security Engineering Capability Maturity Model.

Purpose

It evaluates and improves the maturity of security engineering processes.

SSE-CMM = maturity of security engineering process.

Why SSE-CMM Is Needed

Organizations need security engineering to be:

Need	Meaning
Defined	Process is documented
Repeatable	Same process followed across projects
Managed	Tasks are assigned and monitored
Measured	Metrics are collected
Improved	Lessons learned are used

Maturity Understanding

Maturity Style	Meaning
Initial/ad hoc	Security done randomly/reactively
Repeatable	Some consistency exists
Defined	Documented standard process
Managed	Process monitored and controlled
Optimizing	Continuous improvement using metrics

SSE-CMM Case Mapping

Scenario	Correct Concept
Security only after incidents	Ad hoc maturity
Every team uses different method	Lack of standardization
Documented and followed process	Defined/repeatable process
Metrics and trend analysis	Quantitative management
Pilot implementation	Test small before full rollout
Security integrated into lifecycle	Mature security engineering

18. ITAA 2008

The Information Technology Amendment Act, 2008 strengthened India's cyber law framework around cyber offences, electronic records, data protection, intermediary liability, and penalties.

Important Sections

Section	Meaning
Section 43A	Compensation for negligence in protecting sensitive personal data
Section 66C	Identity theft
Section 66D	Cheating by personation using computer resources
Section 66E	Violation of privacy
Section 66F	Cyber terrorism
Section 67	Publishing/transmitting obscene material electronically
Section 69	Power to intercept/monitor/decrypt information
Section 69A	Blocking public access to online information
Section 72	Breach of confidentiality and privacy
Section 72A	Disclosure of information in breach of lawful contract
Section 79	Intermediary safe harbour

IT Act Exam Mapping

Scenario	Section
Body corporate negligent in protecting sensitive data	43A
Using someone's password/digital signature	66C
Cyber terrorism	66F
Blocking public online content	69A
Intermediary safe harbour	79
Lawful access but unauthorized disclosure under contract	72A

43A = compensation for negligence. 66C = identity theft. 72A = disclosure in breach of contract. 79 = intermediary safe harbour.

19. DPDP Act 2023

The Digital Personal Data Protection Act, 2023 provides for processing digital personal data in a way that recognizes individuals' right to protect their personal data and the need to process data for lawful purposes.

Source: Ministry of Electronics and Information Technology, Digital Personal Data Protection Act, 2023, meity.gov.in

Key DPDP Terms

Term	Meaning
Data Principal	Individual whose personal data relates to
Data Fiduciary	Entity deciding purpose and means of processing
Data Processor	Processes personal data on behalf of Data Fiduciary
Consent Manager	Helps Data Principal manage consent

Personal Data	Data about an identifiable individual
Personal Data Breach	Unauthorized processing/disclosure/access/loss affecting confidentiality, integrity, or availability

DPDP vs GDPR Role Mapping

GDPR	DPDP
Data Subject	Data Principal
Data Controller	Data Fiduciary
Data Processor	Data Processor

DPDP Consent

Consent should be:

Consent Quality	Meaning
Free	No force
Specific	For clear purpose
Informed	Person knows what they agree to
Unconditional	Not bundled unfairly
Clear affirmative action	Clear yes
Withdrawable	Can be withdrawn

DPDP Data Principal Rights

Right	Meaning
Right to information	Know what data is processed and why
Right to correction	Correct/update personal data
Right to erasure	Delete data where applicable
Right to grievance redressal	Raise complaint
Right to nominate	Nominate another person in case of death/incapacity

DPDP Duties of Data Fiduciary

Duty	Meaning
Lawful processing	Process for valid consent or permitted use
Notice	Give clear notice before/with consent
Security safeguards	Protect personal data
Breach intimation	Inform Board and affected Data Principals
Accuracy	Keep data accurate where needed
Data deletion	Delete data when purpose is over unless retention required
Processor control	Ensure processors follow obligations

DPDP Exam Mapping

Scenario	Correct Concept
User whose data is processed	Data Principal
Company deciding why/how data is used	Data Fiduciary
Vendor processing on behalf of company	Data Processor
Consent platform	Consent Manager
Data used for new purpose without consent	Invalid/lack of lawful processing
User withdraws consent	Stop processing unless permitted basis applies
Breach involving customer personal data	Intimate Board and affected Data Principals
User asks what data is processed	Right to information

20. Case Study Cheat Sheet

Case Study: Global Bank Internal Audit

If the question says a bank is being audited for customer data, mention:

Area	What to Check
Lawful basis	Consent/permitted use/legal requirement
Access control	RBAC, least privilege, MFA
Logging	Logs enabled and reviewed
Encryption	Data at rest and in transit
Vendor risk	Third-party processors assessed
Data retention	Data not stored forever
Incident response	Breach response and notification process
Evidence	Policies, logs, reports, tickets, approvals

Sample answer:

The audit should verify privacy, security, access control, third-party, logging, data retention, and incident response controls. Findings should be supported by evidence such as access review reports, encryption configuration, log review records, vendor assessment reports, and breach response procedures.

Case Study: Anti-Corruption Compliance Audit

Focus areas:

Area	What to Check
Gifts and hospitality	Approved limits and records
Vendor onboarding	Due diligence
Payments	No suspicious/unapproved payments
Conflict of interest	Declarations maintained
Training	Anti-bribery awareness
Whistleblower mechanism	Reporting channel exists
Monitoring	High-risk transaction review

Case Study: Internal Audit Finding Format

Use this template:

Observation:

Criteria:

Evidence:

Risk/Impact:

Recommendation:

Corrective Action:

Closure Evidence:

Example:

Observation: Privileged user access in the payment database is not reviewed periodically. Criteria: Access control policy requires quarterly access review. Evidence: User list and missing review records. Risk: Unauthorized access to cardholder data. Recommendation: Implement quarterly access review, MFA, and role-based access. Closure Evidence: Updated access review report and approval records.

Super Important Framework Differentiation Table

Framework/Law	Main Focus	Data/Area Protected	Exam Keyword
ISO 27001	ISMS	Information security	Risk assessment, SoA, ISMS
NIST CSF	Cybersecurity risk management	Cybersecurity posture	Identify, Protect, Detect
GDPR	EU personal data privacy	Personal data	Controller, processor, data subject
DPDP Act 2023	India digital personal data	Digital personal data	Data Principal, Data Fiduciary
HIPAA	Healthcare data	PHI/ePHI	Privacy Rule, Security Rule
PCI DSS	Payment card data	Cardholder data	PAN, CVV, CDE, SAQ
SOX	Financial reporting controls	Financial systems	302, 404, ITGC
SOC 1	Financial reporting impact	Service org controls	Payroll/finance provider
SOC 2	Trust service controls	Security, availability, privacy	Cloud/SaaS provider
SOC 3	Public summary	General assurance	Public report
COBIT	IT governance	Enterprise IT	EDM, APO, BAI, DSS, MEA
ITIL	IT service management	IT services	Incident, problem, change
CIS Controls	Prioritized security practices	Common cyber risks	Inventory, patching, access
CIS Benchmarks	Secure configuration	Systems/devices/cloud	Hardening baseline
SSE-CMM	Security engineering maturity	Security engineering process	Ad hoc to optimized
ITAA 2008	Indian cyber law	Cyber offences/data protection	43A, 66C, 69A, 79

Most Confusing Terms Table

Confusion	Correct Difference
GDPR Controller vs Processor	Controller decides why/how; Processor acts on behalf
DPDP Data Principal vs Fiduciary	Principal = person; Fiduciary = organization deciding processing
HIPAA Privacy vs Security Rule	Privacy = use/disclosure of PHI; Security = safeguards for ePHI
SOX 302 vs 404	302 = CEO/CFO certification; 404 = internal control assessment
SOC 1 vs SOC 2	SOC 1 = financial reporting; SOC 2 = trust services/security
SOC 2 vs SOC 3	SOC 2 = detailed restricted report; SOC 3 = public summary
Type I vs Type II	Type I = point in time; Type II = over period
CIS Controls vs Benchmarks	Controls = what to do; Benchmarks = how to configure
ISO 27001 vs 27002	27001 = requirements; 27002 = control guidance
COBIT vs ITIL	COBIT = governance; ITIL = service management
Audit vs Evaluation	Audit = compliance verification; Evaluation = security assurance
Compliance vs Security	Compliance = follows rules; Security = reduces risk

CCEE Last-Minute Revision Priority

Highest-Yield Areas

Revise these first:

1. ISO 27001 clauses, SoA, ISMS, risk assessment, PDCA
2. NIST functions and examples
3. GDPR roles, principles, rights, breach notification
4. DPDP roles: Data Principal, Data Fiduciary, Processor, Consent Manager
5. HIPAA Privacy/Security/Breach Notification Rules
6. PCI DSS: PAN, CVV, CDE, SAQ, ASV, segmentation, logs
7. SOC 1/SOC 2/SOC 3 and Type I/Type II
8. SOX 302 vs 404 and ITGC
9. COBIT domains and COBIT vs ITIL
10. CIS Controls vs CIS Benchmarks
11. IT Act sections: 43A, 66C, 66F, 69A, 72A, 79
12. Audit phases and evidence-based findings

One-Page Rapid Revision

Topic	Remember This
Compliance audit	Checks rules, controls, evidence
Audit evidence	Logs, screenshots, reports, approvals
Risk-based audit	Audit high-risk/high-impact systems first
Internal audit	Readiness check
Forensic audit	Investigation and legal evidence
Configuration audit	Baseline/hardening review
Audit principle	Evidence-based, independent, confidential
NIST	Identify, Protect, Detect, Respond, Recover; latest adds Govern
ISO 27001	ISMS, risk assessment, SoA, PDCA
GDPR	EU personal data, Controller, Processor, Data Subject
DPDP	Data Principal, Data Fiduciary, Consent Manager
SOX	Financial reporting controls
SOC 1	Financial reporting impact
SOC 2	Security/availability/confidentiality/privacy
SOC 3	Public summary
HIPAA	PHI/ePHI, Privacy/Security/Breach
PCI DSS	Cardholder data, PAN, CVV never after auth
CIS Controls	Prioritized security actions
CIS Benchmarks	Secure configuration baselines
SSE-CMM	Security engineering process maturity
ITAA 2008	Indian cyber law sections

Final Exam Strategy

For MCQs, look for keywords:

Keyword	Answer Direction
financial reporting	SOX or SOC 1
cloud provider trust criteria	SOC 2
public assurance report	SOC 3
health data/ePHI	HIPAA
cardholder/PAN/CVV	PCI DSS
EU personal data	GDPR
Data Principal/Fiduciary	DPDP
ISMS/SoA/risk treatment	ISO 27001
Identify/Protect/Detect	NIST
IT governance/business alignment	COBIT
incident/service desk/SLA	ITIL
secure hardening baseline	CIS Benchmark
prioritized cyber controls	CIS Controls
security engineering maturity	SSE-CMM
identity theft/password misuse	IT Act 66C
negligence protecting sensitive data	IT Act 43A

Your main revision gap is not concept understanding; it is similar-term differentiation. Before CCEE, revise the comparison tables twice: SOC/SOX, HIPAA rules, GDPR/DPDP roles, and ISO clause mapping.